



南京邮电大学
Nanjing University of Posts and Telecommunications

CORECRISIS: 面向威胁引导与上下文感知的 5G 核心网迭代式学习与模糊测试

CORECRISIS: Threat-Guided and Context-Aware Iterative Learning and Fuzzing of 5G Core Networks

Yilu Dong, Tianchang Yang, Abdullah Al Ishtiaq等



汇报人: 刘致远



指导老师: 吴礼发



日期: 2025.3.21

CONTENTS

目录

01

研究背景

02

方法框架

03

结果分析

04

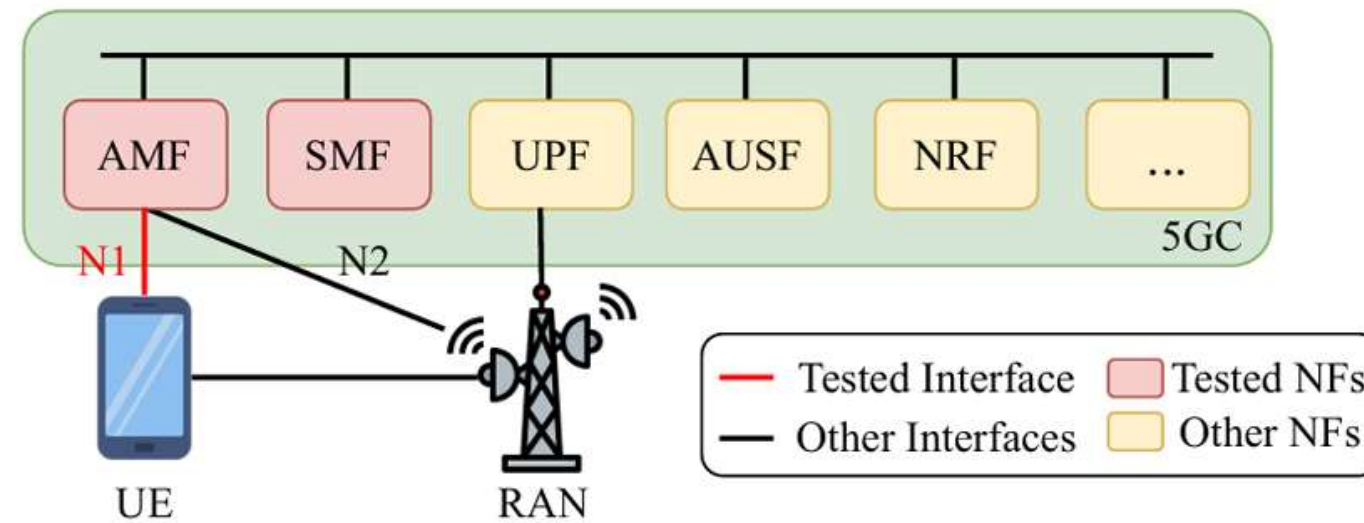
总结展望



01

研究背景

5G核心网架构变化



与以往蜂窝网络的单体架构不同，5G核心网采用基于服务的架构（SBA）

核心特点

- 核心网功能被拆分为多个NFs
- 每个NF作为独立组件运行

优势

- 模块化设计
- 灵活部署与扩展
- 支持云原生架构

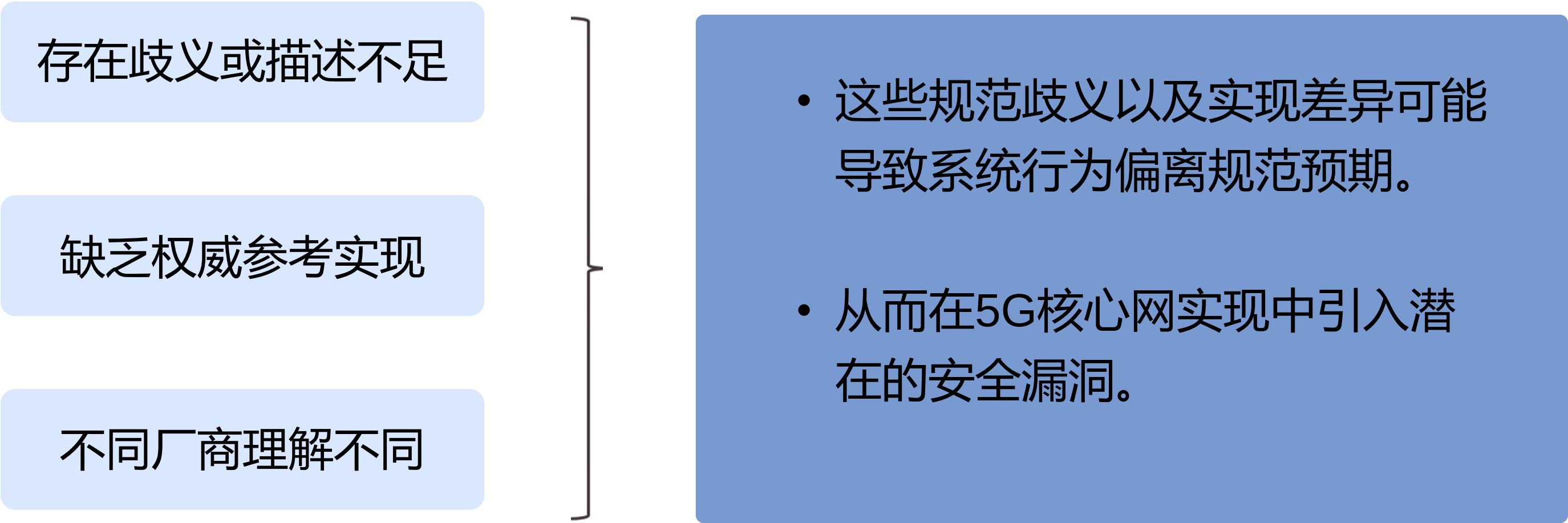
影响

- NF 数量增加
- NF 之间交互复杂

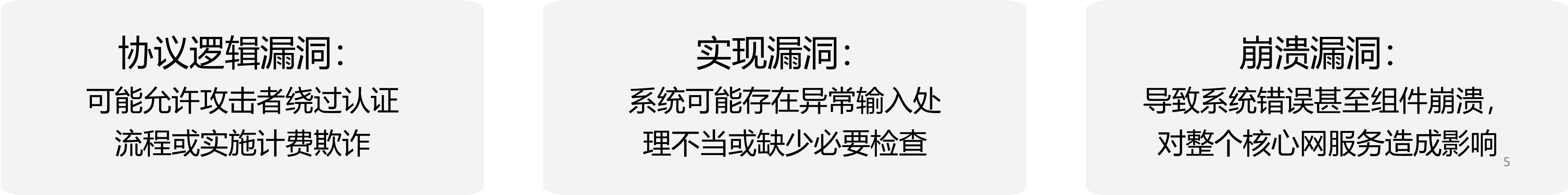
系统整体复杂度显著提升！

规范歧义与实现差异

5G核心网实现主要依据3GPP技术规范，但已有研究发现：



规范歧义和实现差异可能导致：



动机目标

结构复杂性（可拓展性问题C1）

5GCore采用SBA，由多个NFs构成，其全局状态实际上是多个NFs状态的组合，因此状态空间非常庞大。

输入无限性（序列级变异问题C2）

仅仅是有限的正向输入来描述整体功能就已经会导致状态数爆炸。还要考虑数量几乎是无限的负向输入。

本质状态性（黑盒反馈问题C3）

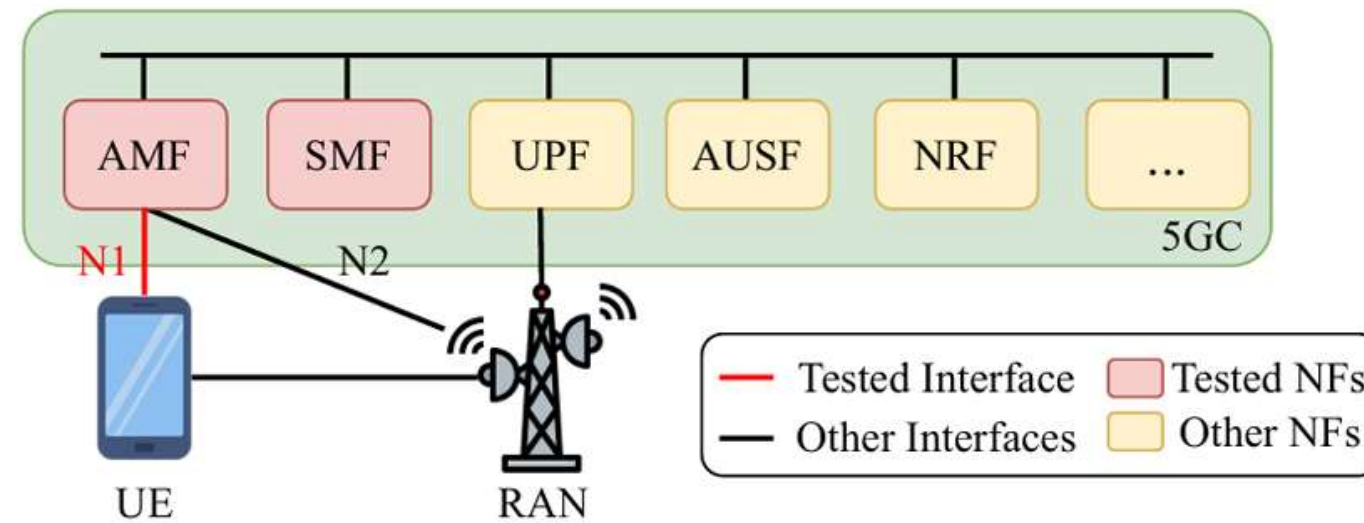
5G Core实现具有强状态依赖，不同输入在不同状态下产生完全不同的行为。因此获取细粒度的反馈信息对主动学习和模糊测试都至关重要。

传统方法不可行！

因此，CoreCrisis的技术创新目标，就是在这种复杂环境下实现可扩展的状态机推断，从而支持对5G核心网实现进行系统化安全分析。

预备知识

5G核心网的关键网络功能



接入与移动性管理功能 (AMF)

- UE 注册与连接管理
- 用户身份认证
- 安全上下文维护
- UE 移动性管理

通过 N1 接口与UE进行通信，使用NAS协议。

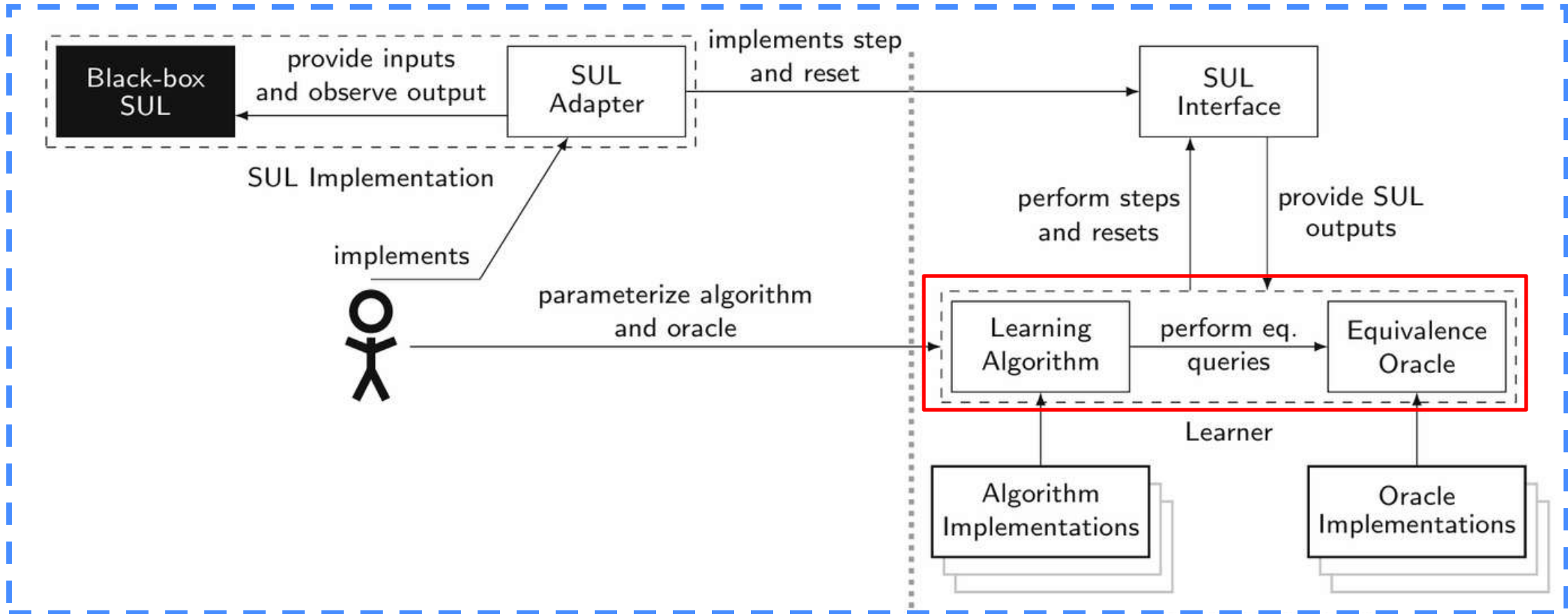
会话管理功能 (SMF)

- PDU 会话建立
- 会话维护
- 会话释放
- 数据路径控制

管理UE与数据网络之间的连接。

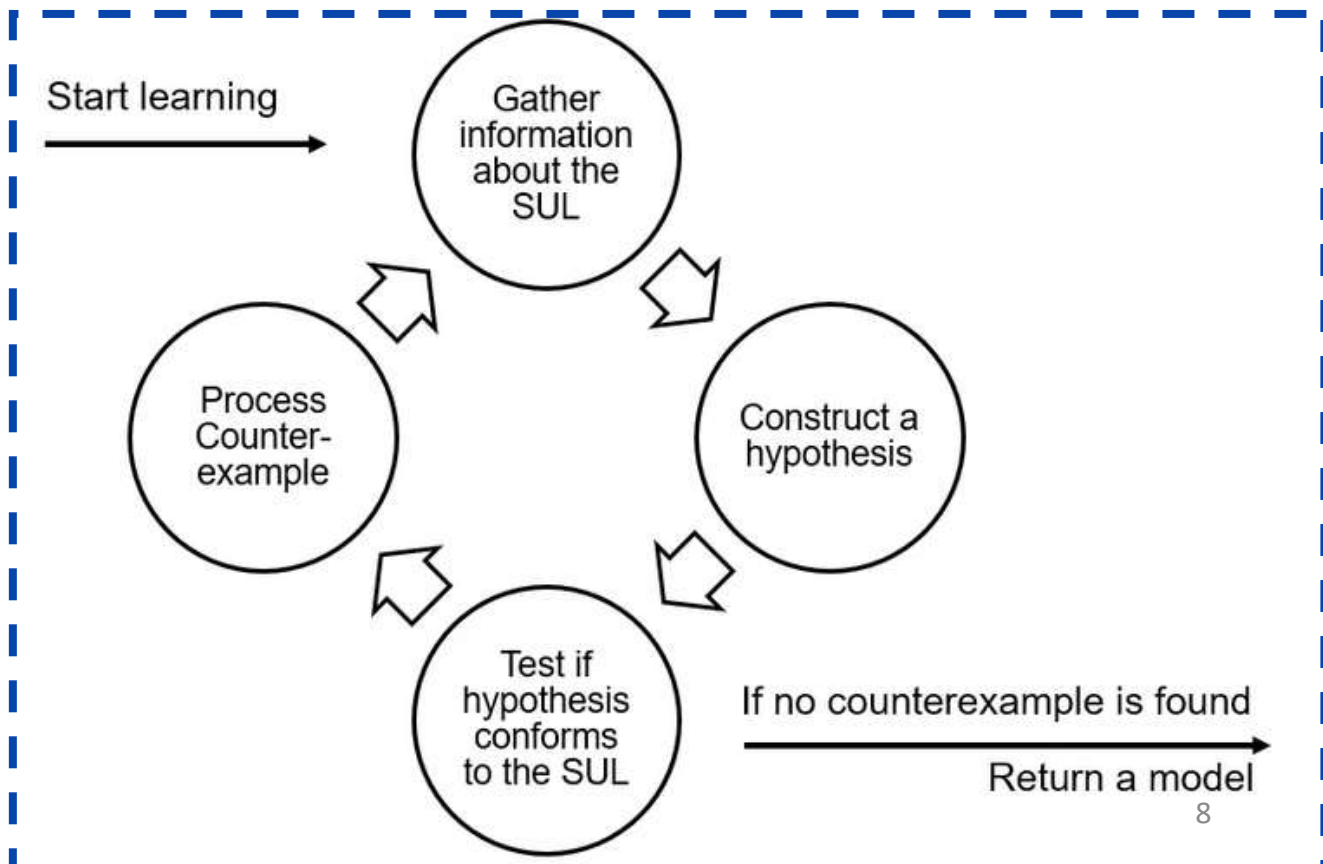
预备知识

自动机主动学习过程



主动自动机学习通常由两个交替执行的阶段组成，即假设模型构建阶段和模型验证阶段。在假设阶段，学习器通过向被学习系统发送成员查询（MQ）获取系统对特定输入序列的响应，并根据这些输入输出构建一个当前的假设状态机模型。在验证阶段，学习器通过等价性查询（EQ）来判断当前假设模型是否能够准确描述真实系统行为。通过重复“构建—验证—修正”的循环，可以逐步逼近真实系统的状态机模型。

自动机学习方法通常可以分为被动自动机学习与主动自动机学习两类。被动学习依赖系统已有的执行日志或运行轨迹。主动学习允许学习器主动向系统发送测试输入，并根据系统返回的输出逐步构建模型，因此能够获得更高的行为覆盖率。





02

方法框架

CORECRISIS 系统实现

系统由三大核心组件构成，协同完成5G核心网的状态推断与模糊测试。



消息适配器

基于UERANSIM开发，新增约4,000行代码，实现抽象符号解释与输入变异。



状态推断模块

基于LearnLib开发，采用 TTT 算法进行状态机学习，并设计属性驱动的等价性检查。



引导测试模块

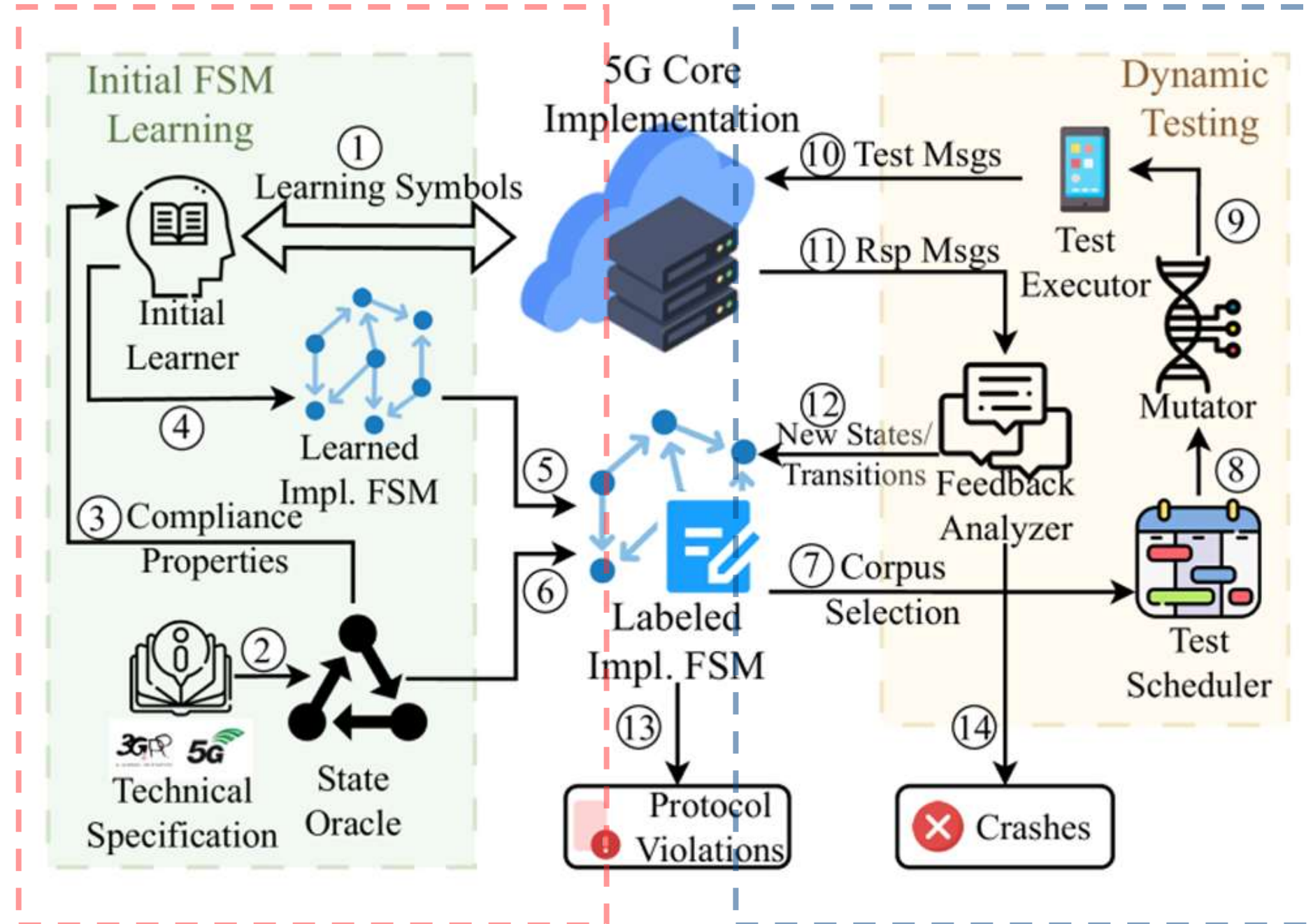
由 Python 实现，约1,200行代码，涵盖模糊测试循环、功率调度、反馈处理与违规判定。

整体概览

CoreCrisis 使用一种两阶段方法，在复杂环境下实现可扩展的状态机推断，从而对5G核心网实现进行系统化安全分析。

① 初始学习阶段

仅使用良性符号构建骨架状态机，引入**分治式学习**与**属性驱动等价性检查**两项技术，解决可扩展性挑战C1。



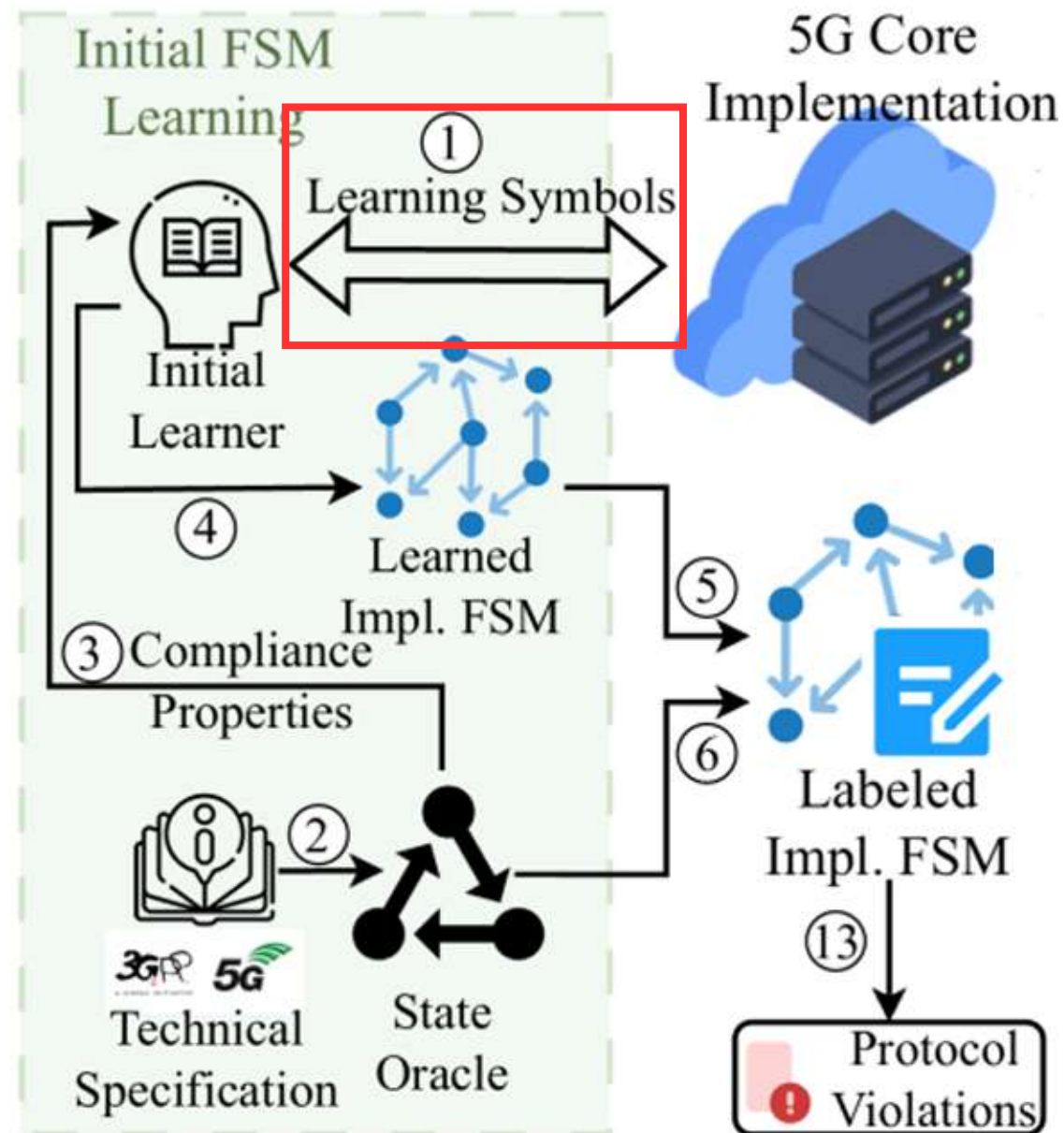
② 动态测试阶段

利用已提取的FSM与状态预言机，**生成有针对性的恶意符号**，探索深层协议状态缺陷，并**动态细化FSM**，解决序列级变异问题C2。

在UE侧构建消息适配器，在初始学习阶段和动态测试阶段，观测Core对测试消息的反应，解决黑盒反馈问题C3。

分治式FSM学习

在流程①处，基于SBA与NF功能划分，将主动学习拆分为两阶段：



阶段一：

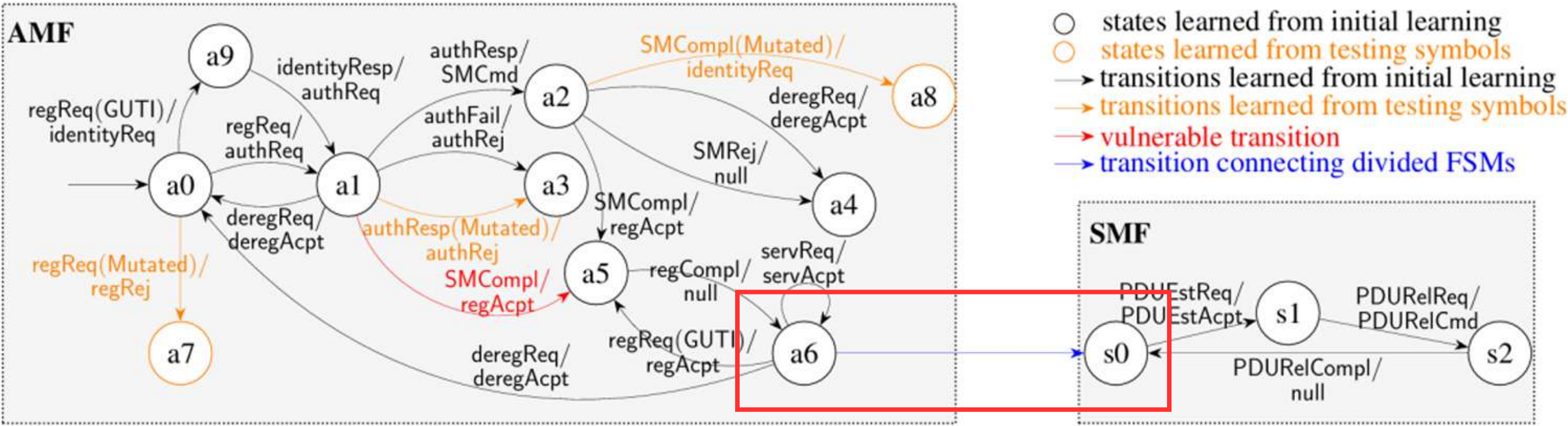
首先学习UE的注册流程，即优先学习AMF模块部分的状态机。

阶段二：

在确保UE已成功完成注册后，再继续学习会话管理流程，此时学习SMF模块部分的状态机。

分治式FSM学习

以参考模型为例:

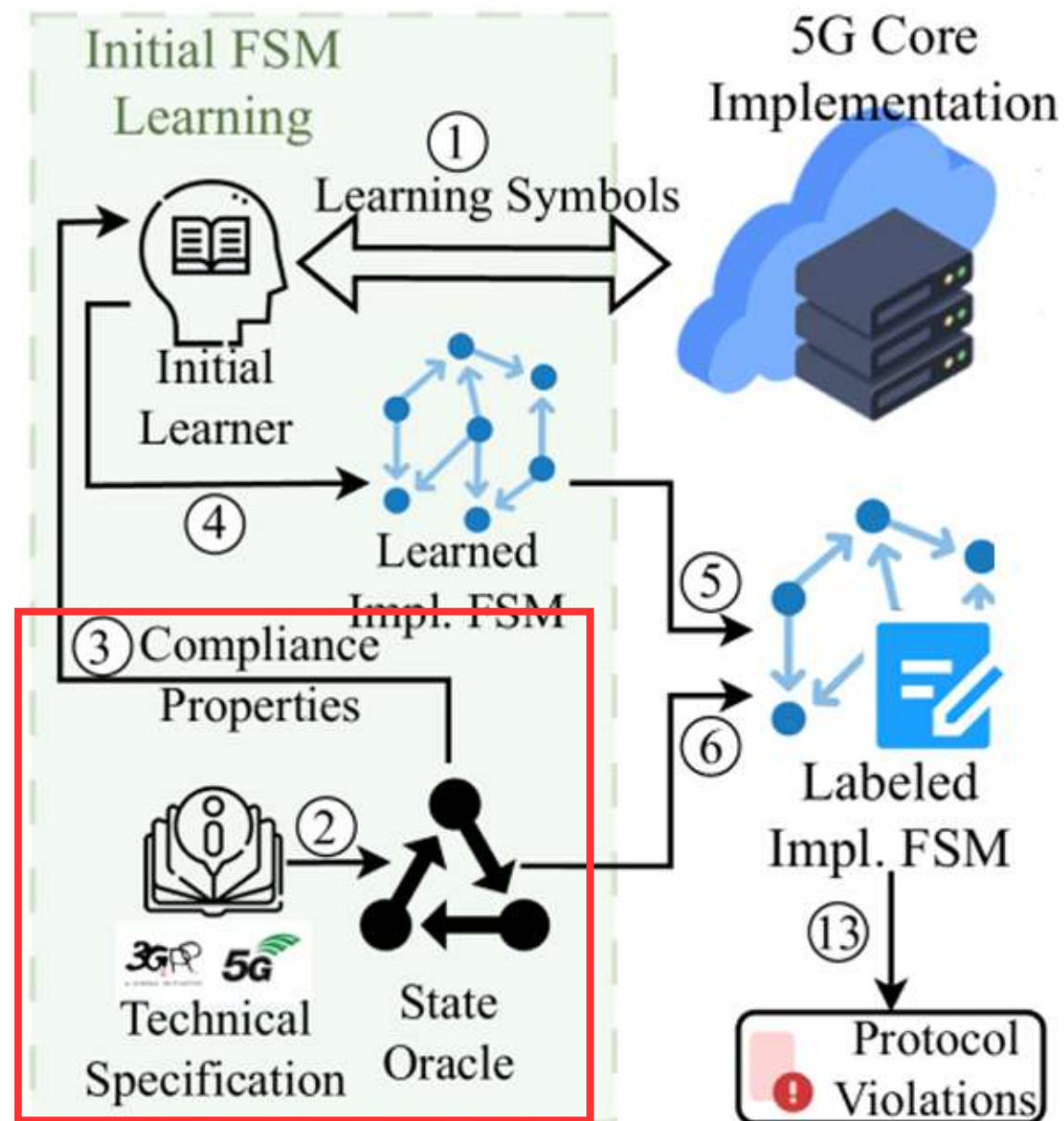


在确保UE已成功完成注册，达到AMF的状态a6后，再以此此刻的状态作为新学习的初始状态s0，继续学习会话管理流程（SMF）。在完成学习后，CORECRISIS按照“会话管理过程只能在成功注册之后发生”这一协议约束，顺序合并这些拆分后的FSM（即连接a6和s0）。最终得到的组合FSM将用于后续的定向测试。

分治策略将高复杂度单体FSM问题转化为多个小型FSM的线性组合，显著提升学习效率与可扩展性。

属性驱动等价性检查

核心思想：实现应当遵循技术规范中定义的高层状态迁移以及正常协议行为属性。



流程② 提取规范：

首先从技术规范中提取各个关键状态所应满足的预期行为要求。

流程③ 属性驱动查询：

这些预期行为被形式化为合规属性，用于生成等价性检查所需的序列，从而能够更有效地细化已学习得到的FSM。

属性驱动等价性检查

PS	State Description	Expected Behaviors
D	Deregistered	Only RegistrationReq accepted
N	Registration-Initiated without authentication or security context	Only plaintext messages accepted ServiceRequest not accepted
A	Registration-Initiated with authentication without security context	Only plaintext and protected msgs SecurityModeComplete accepted ServiceRequest not accepted
S	Registration-Initiated with security context	Only protected messages accepted ServiceRequest not accepted
R	Registered	Only protected messages accepted

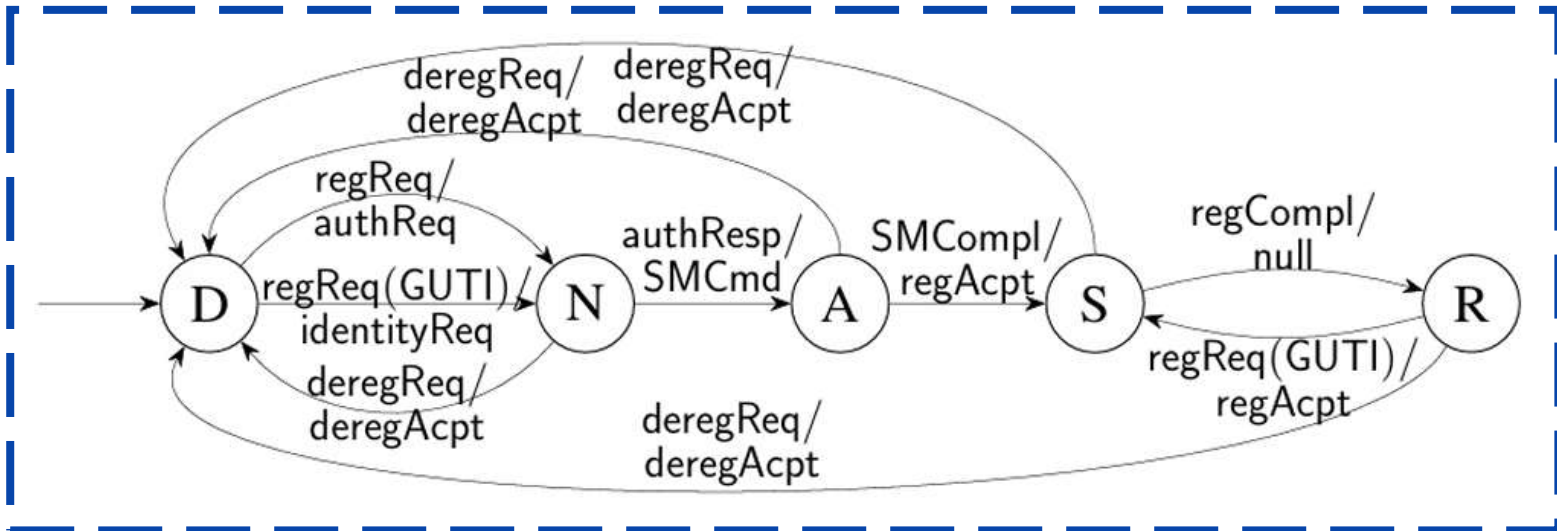
手工提取AMF关键状态和正向行为

- 3GPP. Non-Access-Stratum (NAS) protocol for 5G System (5GS). (TS) 24.501.
- 3GPP. Procedures for the 5G System (5GS). (TS) 23.502.

技术规范定义了若干关键的高层状态迁移，并且这些迁移之间的每一个关键状态都具有明确且不同的行为要求。

规范协议FSM

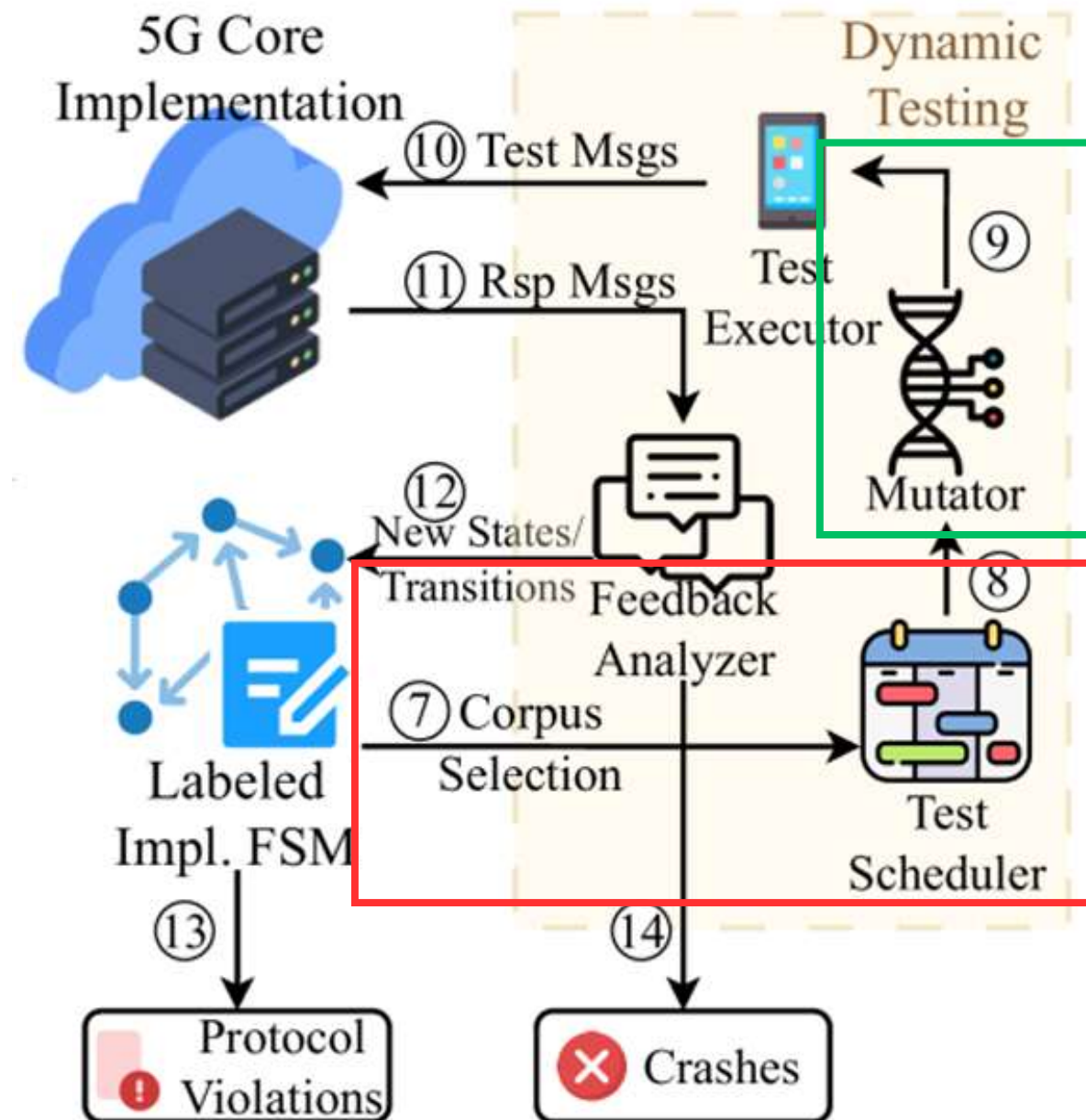
通过提取这些关键协议状态及其状态迁移关系，可以构建一个表示规范中预期行为的协议FSM，用于指导等价性查询（EC）的生成。



测试序列生成

在流程⑦⑧两处实现
功率调度算法。

在所有能够到达该状态的消息序列中，CORECRISIS会选择一条探索程度较低的序列并执行它，以将系统置于期望的目标状态。该序列既可能包含初始FSM学习阶段识别出的良性符号，也可能包含测试阶段引入的变异恶意符号。



为应对挑战C2，在流程⑨处实现了一种两阶段变异策略。

阶段一：

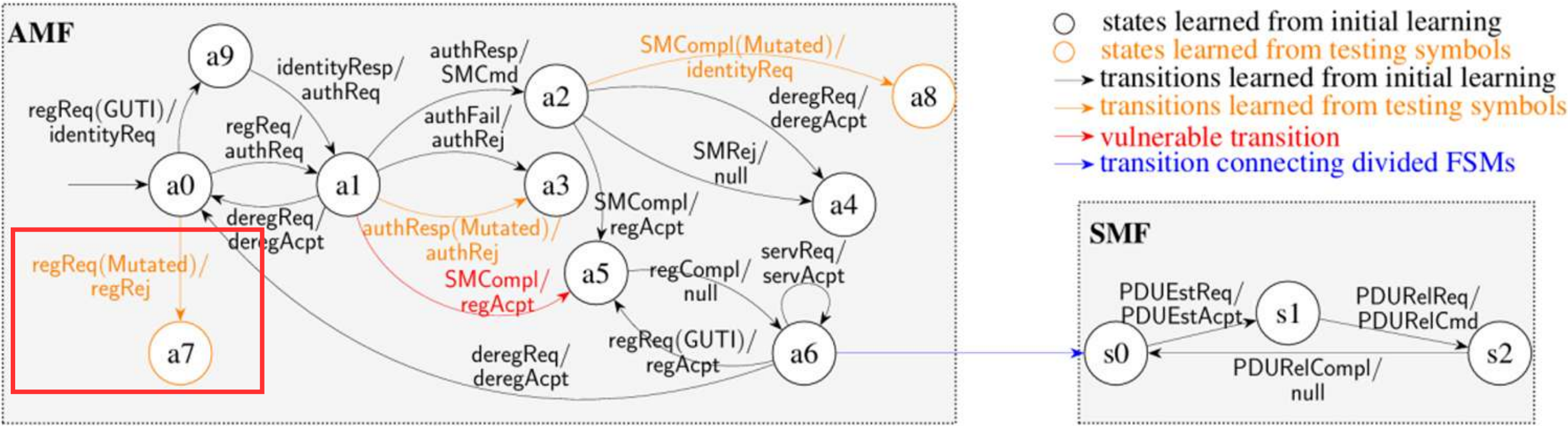
首先执行能到达待测状态的访问序列，将核心网置于期望的目标状态。

阶段二：

向序列中引入一个变异符号，用于探测程序在该既定状态下的行为，从而探索新的状态与迁移。

测试序列生成

以参考模型为例:



考虑在上图中对状态a7进行测试，该状态是在模糊测试阶段识别出的。

在第一阶段，首先发送一个经过变异的regReq，以将核心网置于状态a7。

在第二阶段，多次向序列中引入一个变异符号进行测试。每次测试完成后，CORECRISIS都会评估该变异消息是否导致了新状态或新迁移的发现，或是否触发了漏洞。

构造语法与语义有效的测试消息

序列级变异的挑战

消息的字节级变异由于不理解底层消息结构，几乎总会生成违反语法或语义约束，被5GC直接拒绝的消息。因为规范中使用自然语言描述的语法极其复杂，人工构建消息耗时且易出错。

CORECRISIS的解决方案

复用开源软件UERANSIM的预定义结构与计算函数（MAC、加密、编码），人工识别相关的结构定义及其对应的函数，将消息构造代码改造为消息变异代码。

UERANSIM 的语法感知能力表现在以下三个层面：

语义层面：

- 省略加密
- 或使用错误安全密钥加密

语法层面：

- 使用错误的字段类型
- 或未预期的枚举值

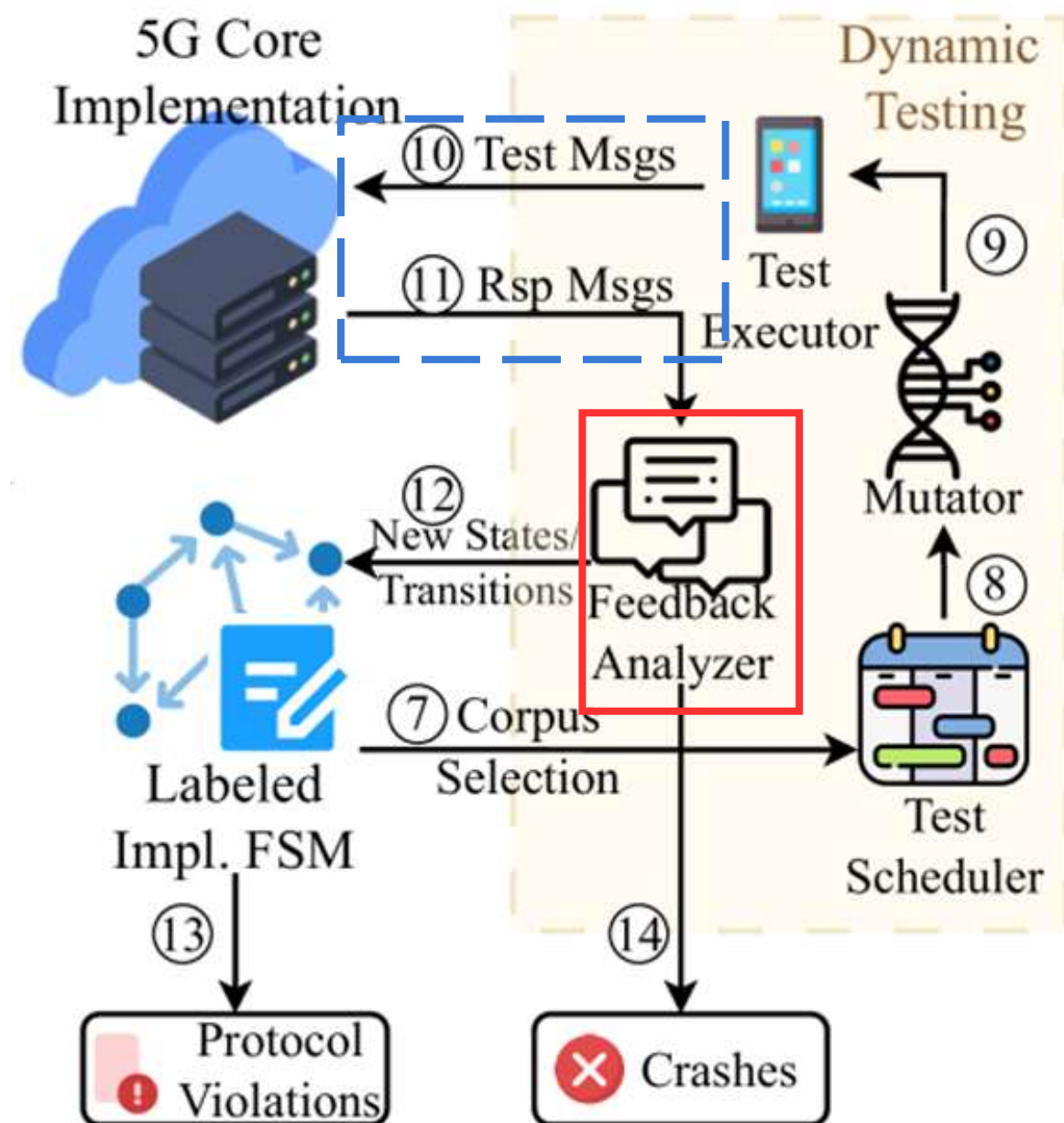
结构层面：

- 直接变异已编码的字节级消息

这种语法感知能力同时支持正向测试（合法消息应被接受）与负向测试（非法消息应被拒绝）。

反馈与新状态学习

经过⑩⑪，对黑盒响应进行分析与比较。



分析响应类型、错误码与响应体内容：

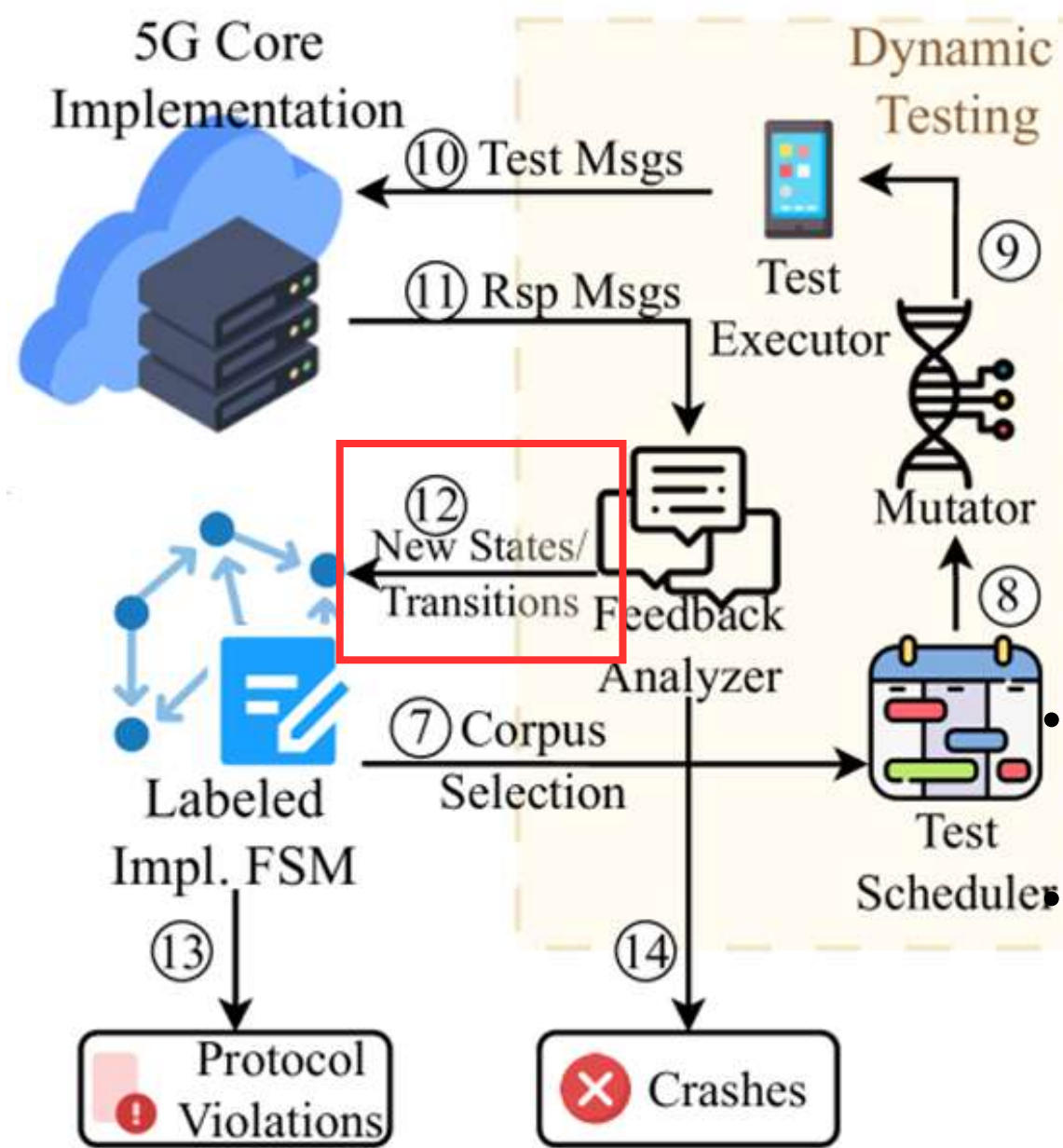
任何与已观测响应不同的响应，均视为发现新状态或新迁移的迹象。

同时忽略动态变化字段：

排除序列号、MAC值等每次变化的字段，避免引入冗余状态。

动态FSM细化

发现此前未见过的响应时，不会重新学习整个自动机，而是只做局部修改。



遇到未见响应

在某状态处进行测试输入并产生了此前未见过的响应。

构造假设状态

首先构造一个假设状态以及一条对应的迁移。

合并或新增状态

若存在等价状态：合并两个状态，并更新相应的迁移。
若不存在等价状态：FSM新增节点，其后继迁移在之后的测试中继续学习。

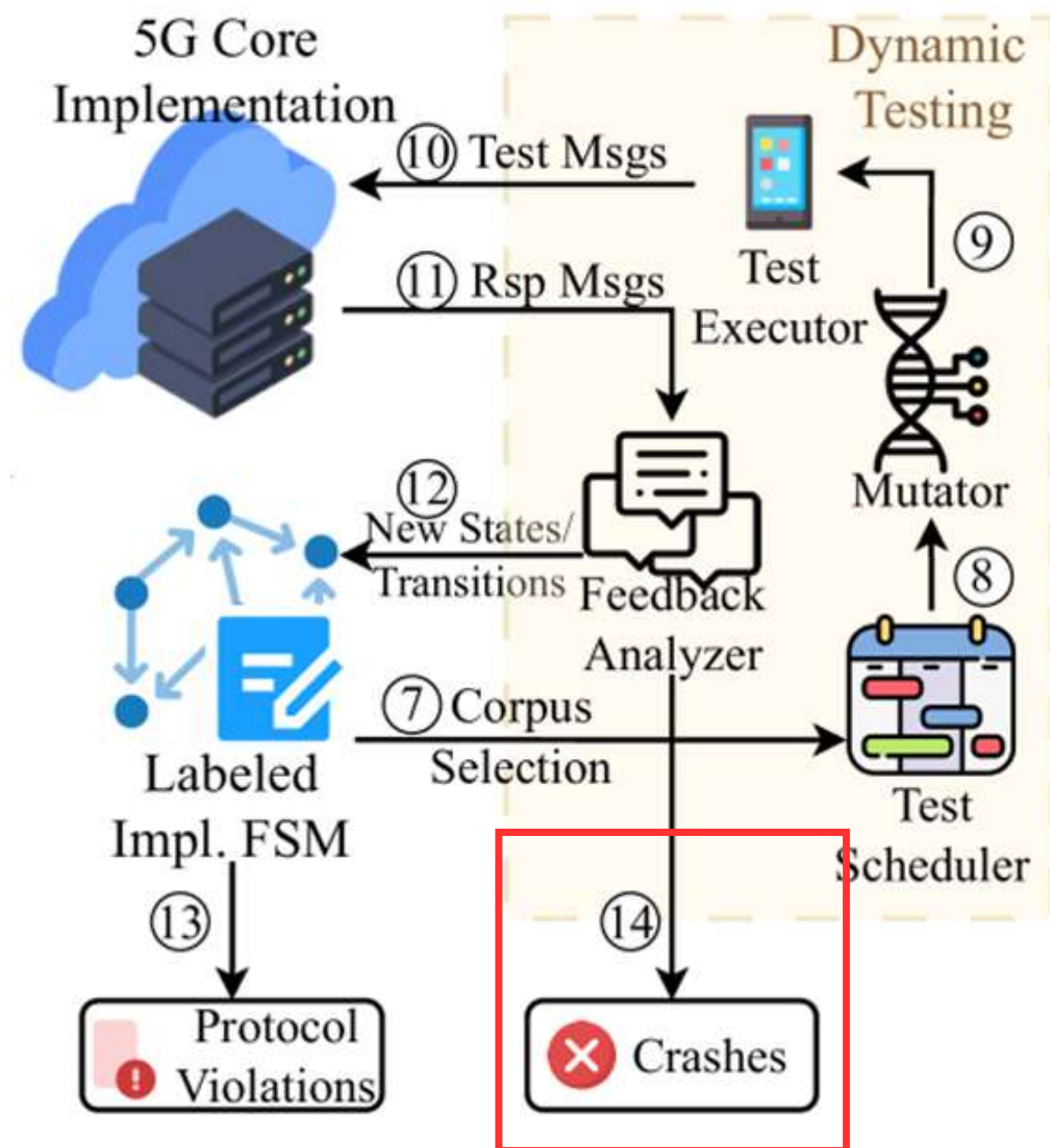
对假设状态验证

在假设状态上测试所有良性输入符号，比较其输入输出行为是否和模型中已有的某状态一致。

迭代式细化能够探索更精细的状态，并发现那些只有通过多次变异才能触发的漏洞。

协议侧信道崩溃检测

通过发送在正常情况下规范要求必然得到响应的消息，探测NF的状态。



AMF 探测

发送携带最近SUPI的 RegistrationRequest，期望收到 AuthenticationRequest响应。

SMF 探测

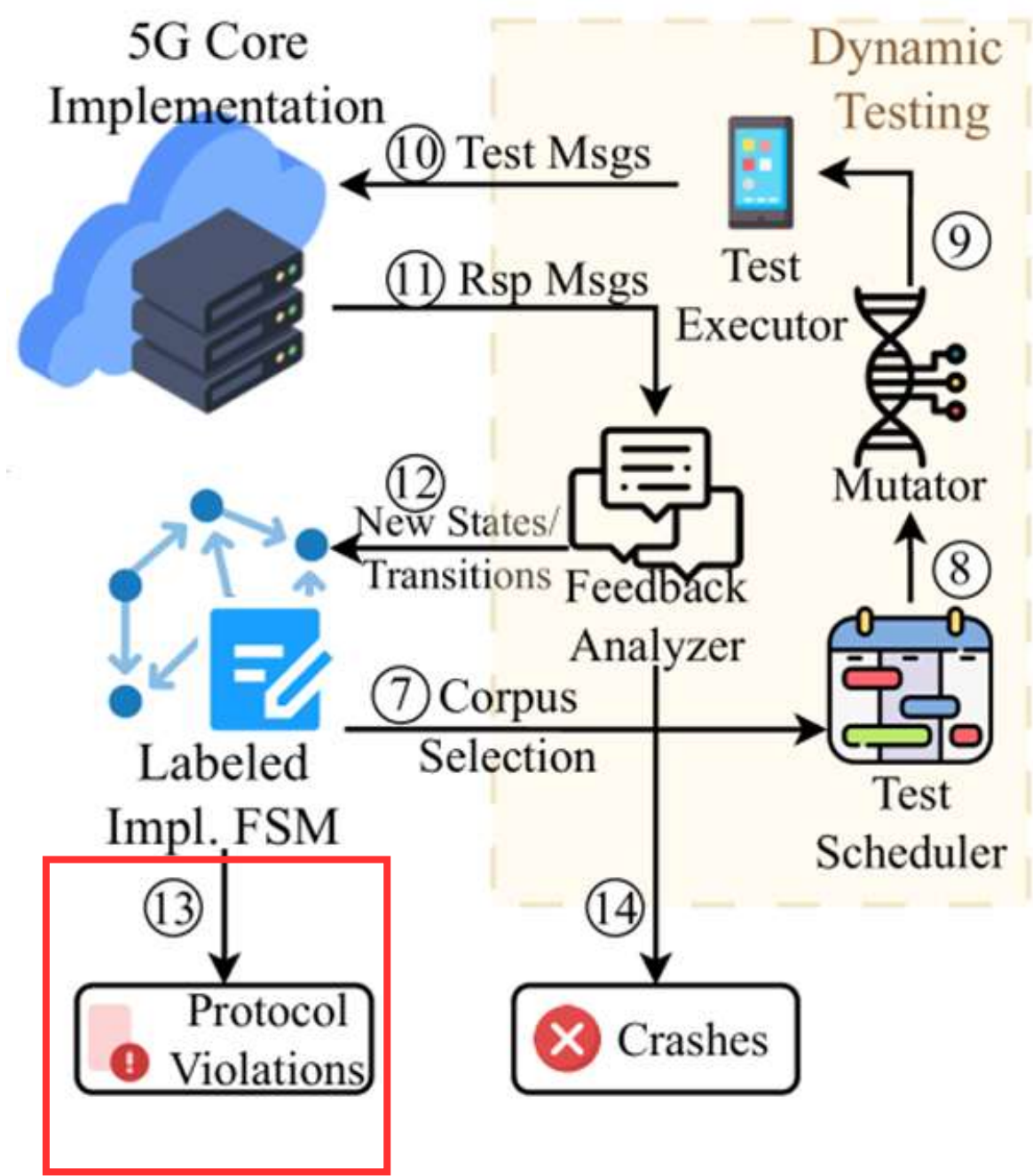
发送 PDUSessionEstablishmentRequest，期望收到 PDUSessionEstablishmentAccept响应。

无响应即存在异常

若无响应，则推断组件已崩溃或进入异常状态。

逻辑错误检测

实现FSM与规范FSM往往存在显著差异，通过**关键协议状态标注**检测逻辑是否一致。



提取协议状态机

首先从技术规范中提取关键高层协议状态机。

状态标注

然后遍历学习得到的FSM转移，为每个节点标注对应的关键协议状态。

一致性验证

最后验证已标注状态是否满足规范要求，系统化检测逻辑错误。



03

结果分析

已识别漏洞总览

系统崩溃
13个由异常负载触发的崩溃漏洞

协议违规
3个可利用的协议违规漏洞

协议偏差
7个相对于技术规范
的协议偏差

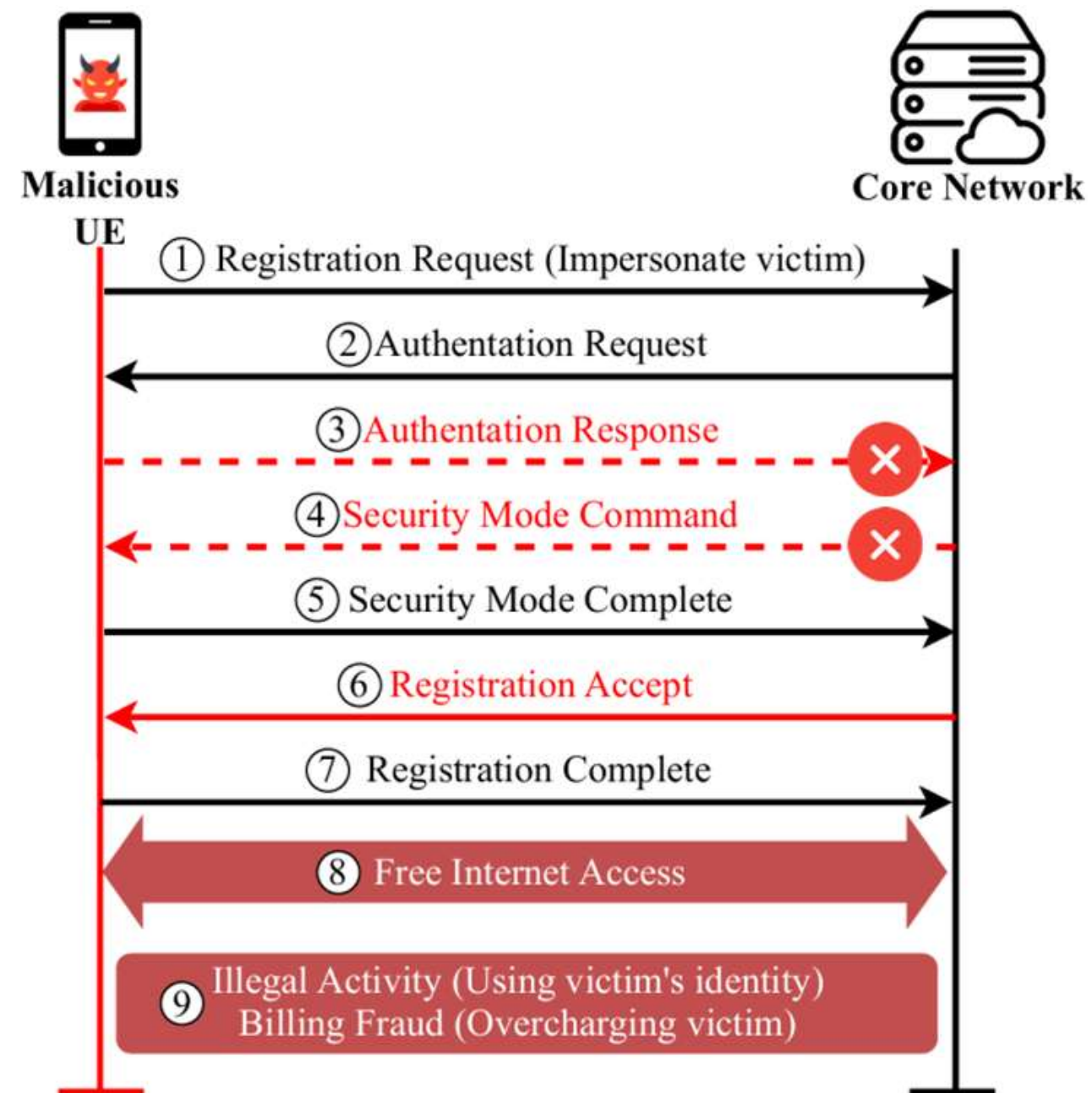
Flaw	Target	Vulnerability/Deviation	Comp.	Impact	CVE Number	New	Stateful	Refine
C1	Open5GS	assertion failure	AMF	DoS	CVE-2024-34476	Y	Y	N
C2	Open5GS	assertion failure	AMF	DoS	CVE-2024-34475	Y	Y	N
C3	Open5GS	assertion failure	SMF	DoS	CVE-2024-33232	Y	Y	N
C4	Open5GS	assertion failure	SMF	DoS	CVE-2024-33232	Y	Y	N
C5	Open5GS	assertion failure	SMF	DoS	CVE-2024-33232	Y	Y	N
C6	free5GC	array index out of bound	AMF	DoS	CVE-2024-22728	Y	N	N
C7	free5GC	array index out of bound	SMF	DoS	CVE-2024-31838	Y	Y	N
C8	OAI-CN-5G	null pointer dereference	AMF	DoS	CVE-2024-33236	Y	N	N
C9	OAI-CN-5G	null pointer dereference	AMF	DoS	CVE-2024-33236	Y	Y	N
C10	OAI-CN-5G	heap buffer overflow	AMF	DoS	CVE-2024-33236	Y	Y	N
C11	OAI-CN-5G	heap buffer overflow	AMF	DoS	CVE-2024-33236	Y	Y	N
C12	OAI-CN-5G	invalid memory access	AMF	DoS	CVE-2024-33236	Y	Y	N
C13	Amarisoft	segmentation fault	AMF	DoS	N/A	Y	N	N
P1	Open5GS	sink state	AMF	DoS	CVE-2024-33233	Y	N	N
P2	OAI-CN-5G	Incorrect message handling	AMF	A.B.	CVE-2024-33241	Y	Y	Y
P3	free5GC	Missing validation check of IMEI/IMEISV	AMF	I.S.	-	Y	Y	Y
D1	Open5GS, OAI-CN-5G	Incorrect transition	AMF	None	-	Y	Y	Y
D2	free5GC, OAI-CN-5G	Respond to invalid SHT (≥ 5)	AMF	None	-	Y	N	N
D3	Open5GS, OAI-CN-5G, Amarisoft	Respond to protected messages before SMCompl	AMF	None	-	Y	Y	Y
D4	Open5GS, OAI-CN-5G	Accept wrong SHT in SMCompl	AMF	None	-	Y	Y	N
D5	Open5GS, free5GC, OAI-CN-5G, Amarisoft	Accepts integrity-protected only messages when the selected algorithm is both integrity-protected and ciphered	AMF	None	-	Y	Y	N
D6	Open5GS, free5GC, OAI-CN-5G, Amarisoft	Respond to wrong SHT protected messages	AMF	None	-	Y	Y	N
D7	Open5GS, OAI-CN-5G	Respond to wrong SHT plaintext messages	AMF	None	-	Y	Y	N

Stateful表示那些在没有状态机引导的情况下无法被检测到的问题。

Refine表示只能通过状态机细化（即在动态学习中）才能发现的问题。

认证绕过漏洞 (P2)

3GPP TS 24.501规定，注册流程须在认证与安全模式控制完成后方可执行。



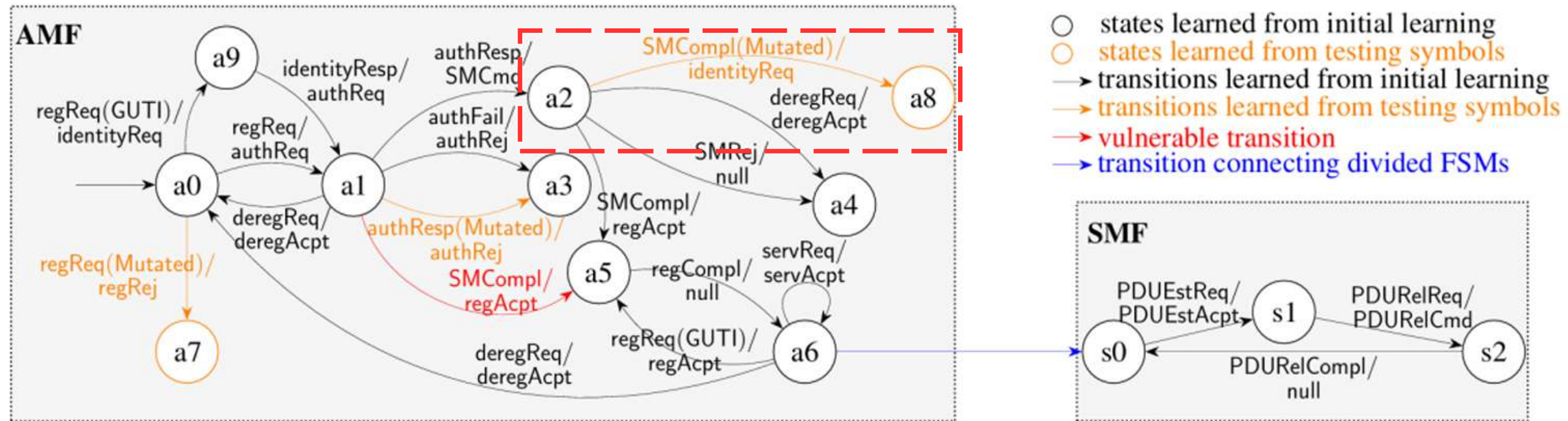
CORECRISIS在 OAI 中发现：攻击者发送明文 SecurityModeComplete 消息后，核心网直接返回 RegistrationAccept，完成注册。

严重后果有：

- 计费欺诈与隐私泄露
- 服务质量下降
- Dos拒绝服务攻击

身份伪造漏洞 (P3)

如下图红框所示，CORECRISIS在 free5GC 中发现：注册阶段系统接受无效的 IMEI 值，未执行合法性校验，带来的风险有：



绕过IMEI黑名单风险:

伪造IMEI可使被盗设备接入网络

注入攻击风险:

恶意输入可能攻破内部数据库

权限提升风险:

注入任意标识符获取特权系统

未授权访问

安全头类型处理不当导致的系统崩溃（C1,C6,C8–C10）

Open5GS、free5GC、OAI 错误假设非零SHT安全头类型消息必含MAC，在无长度校验情况下直接解析，导致崩溃。

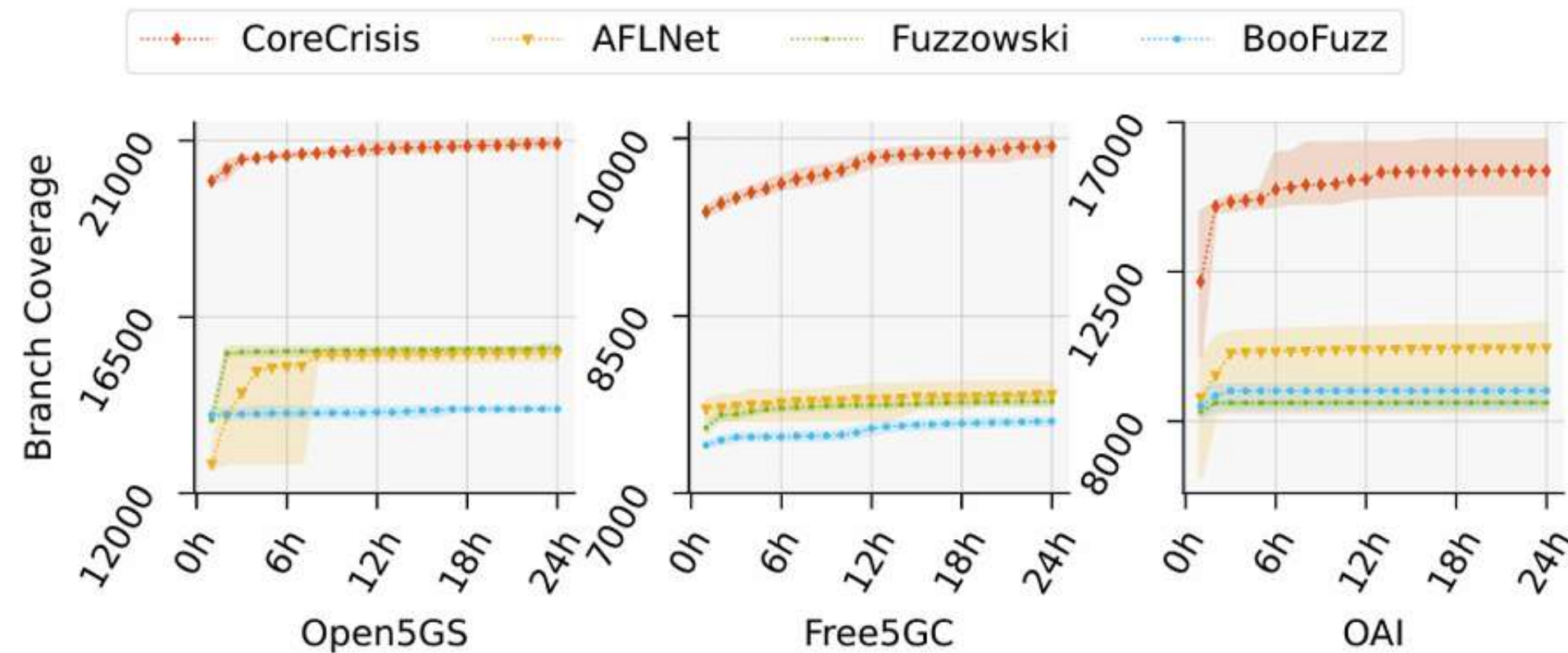
7E	Extended protocol discriminator	octet 1
02	Security header type associated with a spare half octet	octet 2
5F	Message authentication code (MAC)	octet 3
74		...
		octet 6
		octet 7
	Sequence number	octet 8
	Plain 5GS NAS Message	...
		octet n

该崩溃输入0x7E025F74 表示一条明文的SecurityModeReject消息，其安全头类型被设置为2（即完整性保护并加密）。

消息总长度仅包含4个字节。在错误地假设该消息包含MAC的情况下，解码器未对消息长度进行检查，直接尝试从第8个字节开始解析明文NAS消息，从而导致系统崩溃。

与现有模糊测试工具的对比

对比的模糊测试工具有：Boofuzz、Fuzzowski、AFLNet。在三个开源实现上对每种工具进行了24小时的评估，并使用相同的初始语料集和重置方法。



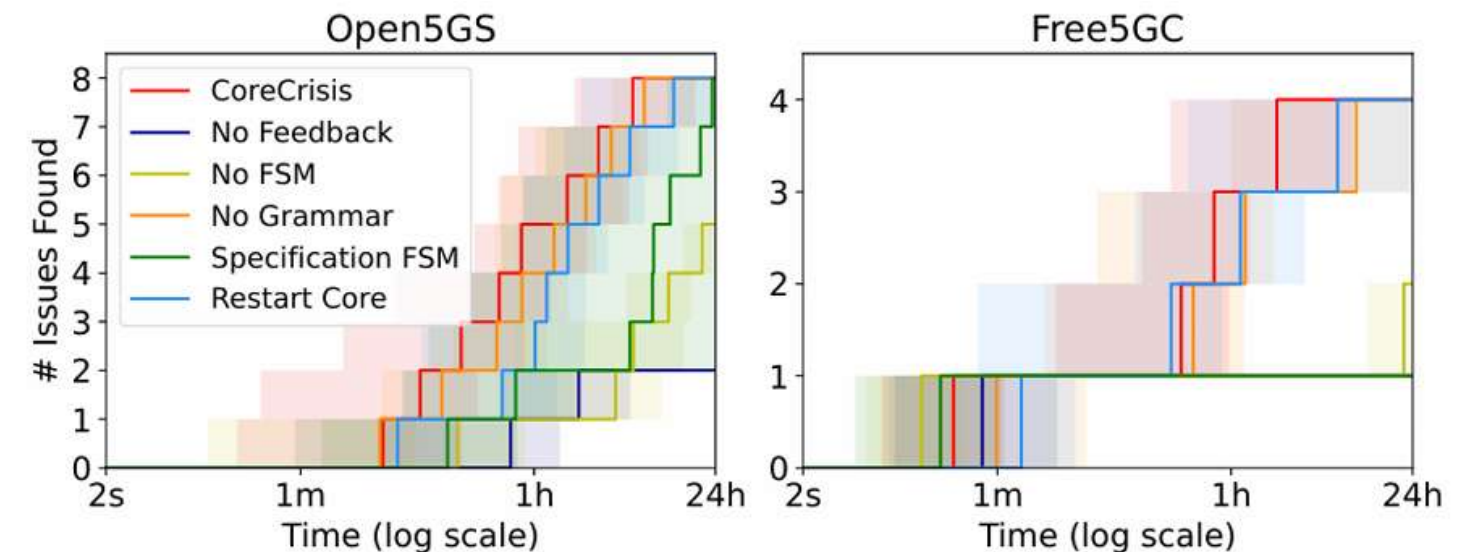
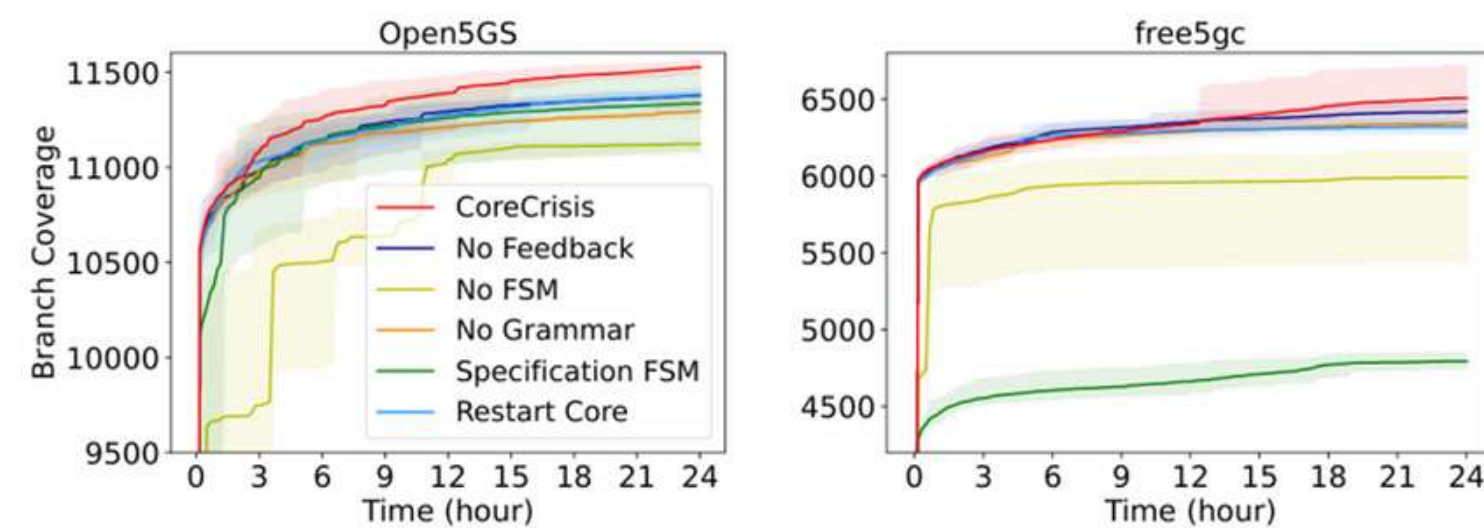
唯一发现逻辑漏洞：
CORECRISIS检测到3个协议违规，
其他工具仅能发现系统崩溃。

检测速度：
Fuzzowski最快
Boofuzz其次
CORECRISIS最慢

检测效果：
CORECRISIS实现了最高的代码覆盖
率，并发现了数量最多的漏洞。

消融实验

消融实验在Open5GS与free5GC上运行24小时×10次，结果如下



消融研究覆盖率评估

结果显示，FSM引导的有状态测试机制对覆盖率提升贡献最大；当完全不使用FSM或仅依赖规范FSM时，测试效率和覆盖能力均显著降低。这表明结合实现状态机的反馈驱动测试能够更有效探索协议状态空间。

独特崩溃与逻辑偏差

在23个已识别问题中 78.3%属于有状态漏洞，这些漏洞仅能在特定协议状态下触发；此外，部分漏洞仅能在状态细化后的新状态或新转移中被发现。因此，准确识别新的状态与转移并动态更新FSM对于发现协议逻辑错误至关重要。



04

总结思考

总结思考

01

论文贡献

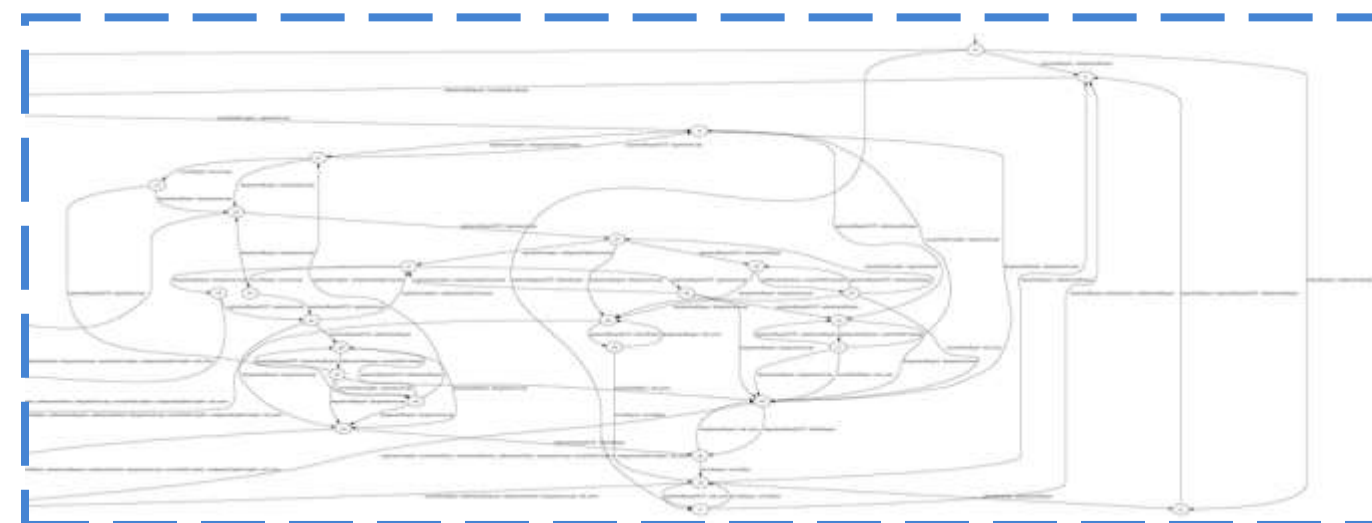
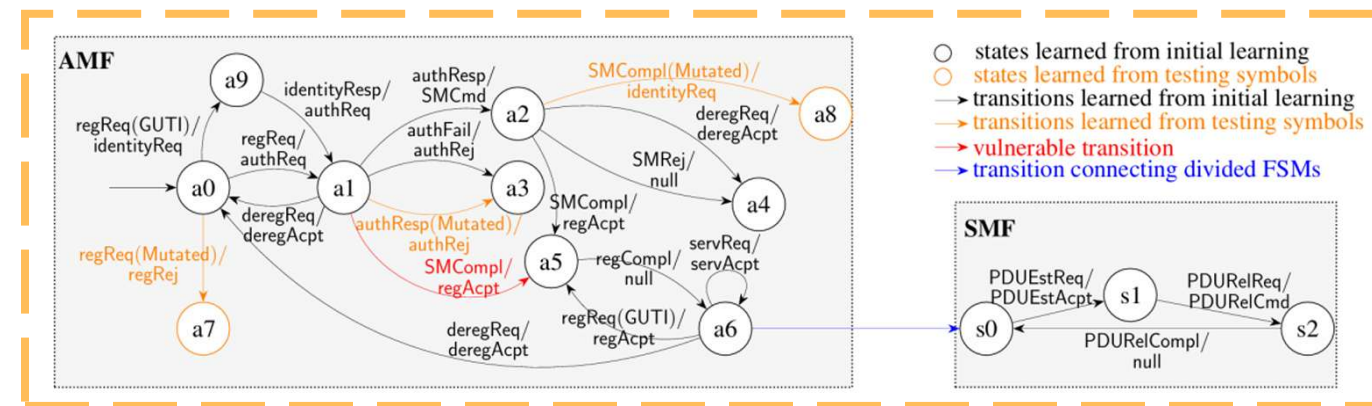
- 1.提出首个针对5GC进行自动推断并进行安全测试的框架。
- 2.提出分治式FSM学习、属性驱动的等价性检查以及动态状态细化等机制，有效应对5GC状态机的可扩展性问题，实现精确建模，提高检测效率。

02

局限

- 1.当前框架主要针对 NAS 消息以及 AMF 和 SMF，尚未扩展到其他消息类型（如 RRC）或更多网络功能。
- 2.自动机学习算法只能保证观测正确性而非完备性，因此学习得到的 FSM 可能仍存在未覆盖的状态或转移。

复现反思



论文并未给出三个开源5GC的完整参考状态机模型。论文中多次使用的参考图实际是基于 OAI 实验结果的美化示意图，但文中却在该图上讨论了 free5GC 的身份伪造漏洞。Open5GS 和 free5GC 的真实实现状态机在论文中均不可见。

进一步复现发现，官方开源代码仅提供 Open5GS 的状态机推断框架。在严格按照论文环境配置 Open5GS 与 UERANSIM 后，出现状态爆炸的问题（约40状态）。而参考状态机仅15个状态，且行为存在明显逻辑不一致。

这一差异可能带来重要影响：论文假设初始主动学习得到的FSM在**观测层面上是正确的**，而后续模糊测试阶段仅通过动态细化对FSM进行**局部更新**。然而，如果初始FSM本身包含**由学习不完全导致的错误逻辑分支**，动态细化机制可能无法修正这些结构性错误，从而影响协议行为分析与漏洞检测结果。因此可以进一步深入研究以下三个问题。

1. 如何对真实实现中出现状态爆炸的结果进行合理约简？

2. 若初始FSM存在逻辑错误，动态细化机制如何进行修正？

3. 初始状态机误差对协议漏洞检测结果会产生多大影响？

THANK YOU FOR ATTENTION

谢谢大家

